

--- ---		
Infrastructure	Hetzner CX43 (Minecraft) ·	Ubuntu 24.04 LTS
Domain	geigercapital.us	
Modpack	Homestead 1.3.6 · Fabric 1.20.1	
Repository	github.com/erxxc/homestead-sdlc (public)	
Compliance Target	SOC 2 TSC · ISO 27001 Annex A · CIS Ubuntu 24.04 · NIST CSF	
Assessment Date	2026-04-26 (v1.0)	
Update Date	2026-05-23 (v1.1 – post-sweep)	
Status	Readiness Assessment Complete · Continuous-improvement phase	

Executive Summary

This document presents the results of a weekend secure software development life cycle proof-of-concept implemented on a live Minecraft multiplayer server infrastructure. The project demonstrates that enterprise-grade security controls, monitoring, and compliance documentation can be implemented on consumer infrastructure using exclusively free and open-source tooling.

v1.1 reflects post-PoC continuous improvements: modpack upgrades through 1.3.6, supply-chain automation, audit logging refinements, and reconciliation of pentest findings against current production state.

Metric	Value	Notes
--- --- ---		
Controls Implemented	30	Mapped to SOC 2, ISO 27001, NIST CSF
Pentest Findings	18	7 of 8 non-accepted actionable findings fully remediated; F-001 partial
Lynis Score	67/100	Improved from baseline of 65
Services Monitored	4	Minecraft, BlueMap, SSH, Voice Chat
CI/CD Pipelines	5	CodeQL, Checkov, ZAP, Dependabot, Deploy
Server-side Mods	427	All under SHA-256 integrity tracking
Uptime (last 30 days)	99%+	1 planned maintenance window per scheduled-rest art cadence

Infrastructure Overview

Architecture

The infrastructure consists of a single Hetzner CX43 VPS running Ubuntu 24.04 LTS. All services run as isolated systemd units under dedicated non-root service accounts. Network exposure is controlled by dual firewall layers – UFW at the OS level and Hetzner's network firewall at the infrastructure level.

Component	Technology	Purpose
--- --- ---		
Game Server	Minecraft 1.20.1 / Fabric / Homestead 1.3.6	
Web Proxy	Nginx 1.24	
Live Map	BlueMap 4.1	
Status API	Flask / Python 3	
Metrics	Prometheus + Node Exporter	
Dashboards	Grafana	
Uptime	Uptime Kuma	

Audit Log	Custom Python daemon	Structured security event trail
Mod Integrity	inotify watcher + SHA-256	Auto-regenerate baseline on approved jar changes
Scheduled Restart	RCON-driven script	Announce, save-all flush, systemd restart, audit log
Backup Verification	Weekly integrity check	Restore validation against retained backups
TLS	Let's Encrypt / certbot	HTTPS on all web-facing services
DNS / CDN	Cloudflare	DNS, DDoS protection, Pages hosting
Public Site	Cloudflare Pages	Player-facing status site + guide + changelog
CI/CD	GitHub Actions	Automated security scanning and deployment

SDLC Implementation

Phase	Deliverable	Description
---	---	---
Phase 1 – Threat Modelling D01 STRIDE analysis across SSH, RCON, Minecraft protocol, BlueMap, mod supply chain, KubeJS scripts, and CI/CD pipeline. 10-item risk register with likelihood, impact, and control mapping. v1.1 sweep updates status fields against current production state.		
Phase 2 – Secure Configuration D03, D06 CIS Ubuntu 24.04 baseline via Lynis (65 → 67). Kernel hardening, auditd, secure shared memory, login banners. RCON credentials migrated from plaintext to restricted secrets file (chmod 640, root:minecraft).		
Phase 3 – Supply Chain Integrity D05 SHA-256 checksums generated for all 427 mod jars. Automated verification runs as systemd `ExecStartPre` – server refuses to start if any checksum fails. inotify watcher auto-regenerates the baseline on approved mod additions/updates. SBOM documents provenance of 6 CurseForge-exclusive FTB mods.		
Phase 4 – Monitoring D04 Prometheus scraping Node Exporter and Minecraft Exporter. Grafana dashboard with 6 panels. Uptime Kuma monitoring Minecraft, BlueMap, and SSH with Discord alerting.		
Phase 5 – Audit Logging D04 Python daemon classifies player join/leave, OP grants/revocations, kicks, bans, RCON commands, integrity check results, and server start/stop into structured JSON. Scheduled-restart script also emits SERVER_STOP and SERVER_START events.		
Phase 6 – Penetration Testing D07 Self-assessment using nmap, nikto, OWASP ZAP, and manual testing. 18 findings across Critical(0), High(1), Medium(7), Low(5), Informational(5). Real-world attack evidence in Nginx logs within hours of go-live.		
Phase 7 – Status API and Site D10 Flask API serving sanitised public metrics with tightened exception handling. Nginx reverse proxy with full security header suite. Let's Encrypt TLS on all web-facing services. Cloudflare Pages site with live JavaScript status widget, getting-started guide, and changelog page.		
Phase 8 – Compliance Documentation D02, D08, D09 30-control framework mapped to SOC 2 TSC, ISO 27001 Annex A, and NIST CSF. Three incident response runbooks. Privacy notice documenting data inventory, retention, and player rights.		
Phase 9 – CI/CD Pipeline D11 GitHub Actions: CodeQL SAST, Checkov IaC, OWASP ZAP DAST, Dependabot, automated VPS deployment on merge to main. gitleaks pre-commit hook. Branch protection requires PR review.		
Phase 10 – Operational Hardening (v1.1) D13 Post-PoC additions: log rotation (30-day retention on audit and Nginx logs), backup verification script, scheduled restart with player announcements, BlueMap POI markers.		

Penetration Test Summary

A self-assessment was conducted using nmap, nikto, OWASP ZAP, and manual testing . v1.1 reflects updated remediation status after post-PoC fixes (HSTS, CSP, Permissions-Policy, server-version disclosure, port exposure).

ID	Finding	Severity	Status
F-001	RCON password in process list	High	Partially Remediated
F-002	Missing CSP header	Medium	Remediated
F-003	Active automated scanning	Info	Accepted
F-004	Deploy key no passphrase	Medium	Accepted
F-005	BlueMap HEAD request 400	Info	Accepted
F-006	Nginx version disclosure	Low	Remediated
F-007	Voice chat UDP exposure	Low	Accepted
F-008	Minecraft version disclosure	Low	Accepted
F-009	BlueMap port 8100 exposed	Medium	Remediated
F-010	Rate limiting blocking scanners	Info	Closed (positive)
F-011	Missing HSTS header	Medium	Remediated
F-012	Missing Permissions-Policy	Low	Remediated
F-013	Missing headers on API	Medium	Remediated
F-014	Nikto outdated	Info	Accepted
F-015	Nikto platform misidentification	Info	Accepted
F-016	HTTP only on VPS services	Medium	Remediated
F-017	CSP weaknesses BlueMap	Medium	Accepted
F-018	Timestamp disclosure API	Low	Accepted

Summary Statistics

- Total findings: 18
- Critical: 0
- High: 1 (F-001 partially remediated)
- Medium: 7 (5 remediated, 2 accepted)
- Low: 5 (2 remediated, 3 accepted)
- Informational: 5 (4 accepted, 1 closed as positive control)
- Remediation rate: 7 of 8 non-accepted actionable findings fully remediated; F-001 partial (exporter CLI exposure remains pending upstream config-file support)

Compliance Posture

This PoC produces a SOC 2 readiness package – a documented control environment that a licensed auditor could assess against the Trust Services Criteria. Git history provides a timestamped, attributed audit trail of all infrastructure changes – directly evidencing change management controls.

Standard	Coverage	Notes
SOC 2 Type 1	Security, Availability, Confidentiality	30 controls documented and evidenced. Git history provides change management audit trail. Monitoring and alerting demonstrate detection capabilities. Incident runbooks address C7.3.
ISO 27001	Annex A – A.9 through A.17	Gap assessment complete. Domains covered: access control (A.9), cryptography (A.10), operations security (A.12), communications security (A.13), system development (A.14), incident management (A.16), business continuity (A.17).
CIS Ubuntu 24.04	Lynis benchmark	Baseline score 65, post-remediation score 67. Kernel hardening, auditd, secure shared memory applied. Remaining gaps accepted due to game server operational constraints.
NIST CSF	All five functions	Identify: threat model, SBOM. Protect: 20+ controls. Detect: Prometheus, Grafana, Uptime Kuma, audit log, CodeQL. Respond: 3 runbooks. Recover: daily backups with 7-day retention + weekly verification.

| ****GDPR**** | Data minimisation and retention | Data inventory documented. Retention periods defined. Privacy notice published. Player rights procedure established. Lawful basis documented as legitimate interest. |

Threat Model – Current Status (v1.1)

Sweep against 10-item risk register; statuses reflect production reality as of 2026-05-23.

Risk ID	Component	Threat	Risk Level	Status
R-001	RCON	Password in plaintext	Critical	Partial – secrets file migrated; F-001 exporter exposure remains
R-002	Minecraft	Packet flood / DDoS	High	Planned – UFW rate limiting pending
R-003	Mod Supply Chain	Arbitrary code execution	High	Implemented – checksums + mod-watcher
R-004	Minecraft	No chat audit log	High	Partial – session events captured; chat lines not classified
R-005	RCON	No command audit log	High	Implemented – RCON_COMMAND in audit log
R-006	GitHub	Secret in committed code	High	Implemented – gitleaks pre-commit
R-007	BlueMap	Directory traversal	High	Tested – no ZAP finding
R-008	KubeJS	No script change audit	High	Implemented via git
R-009	SSH	No session audit trail	Medium	Implemented – auditd active
R-010	GitHub	Compromised deploy key	High	Implemented – restricted permissions

Deliverables

ID	Deliverable	Status	Location
D01	Threat Model	Complete	`docs/threat-model/threat-model.md` (v1.1 sweep)
D02	Control Framework	Complete	`docs/control-framework.md`
D03	CIS Benchmark Report	Complete	`reports/lynis-baseline-summary.md`
D04	Monitoring Dashboard	Complete	Grafana + Uptime Kuma (live) – see `monitoring/*/README.md`
D05	Supply Chain Integrity	Complete	`docs/sbom.md` + systemd ExecStartPre + inotify watcher
D06	Secrets Management	Complete	`docs/secrets-management.md`
D07	Penetration Test Report	Complete	`docs/pentest-report.md` (reconciled)
D08	Incident Response Runbooks	Complete	`docs/runbooks/` (IR-001, IR-002, IR-003)
D09	Privacy Notice	Complete	`docs/privacy-notice.md`
D10	Public Site	Complete	play.geigercapital.us (live)
D11	CI/CD Pipeline	Complete	`.github/workflows/` (5 pipelines)
D12	PoC Summary Report v1.0	Complete	`reports/2026-04-26-poc-summary.pdf`
D13	Operational Hardening (v1.1)	Complete	mc-restart.sh + verify-backup.sh + minecraft-logrotate.conf + BlueMap POI markers
D14	PoC Summary Report v1.1	Complete	This document

Recommendations

Immediate

- Investigate exporter replacement to fully remediate F-001 RCON process exposure
- Enable Cloudflare proxy (orange cloud) on map and api subdomains for DDoS protection
- Implement UFW rate limiting on Minecraft port 25565 (closes R-002)

Short Term

- Extend audit logger to classify in-game chat lines (closes R-004 fully)
- Extend integrity monitoring to KubeJS scripts directory (closes Phase 1 KubeJS T-row)
- Implement HashiCorp Vault for secrets management at scale
- Set up log aggregation with tamper-evident storage (Loki or Elasticsearch)
- Tighten CI lint gates (currently `|| true` on black and `continue-on-error` on markdown-lint)

Long Term

- Pursue formal SOC 2 Type 1 audit with licensed CPA firm
- Migrate to Fabric Prometheus Exporter mod when a 1.20.1-compatible version is available
- Implement network segmentation via Hetzner private networking if a second VPS is added
- Consider Cloudflare Tunnel to eliminate direct VPS IP exposure
- Upgrade to .com domain for full WHOIS privacy

Homestead SMP – SDLC PoC v1.1 · May 2026 · Confidential